

Threat Intelligence

Accelerated Cyber Security Transformation: Time. The Nameless APT

December 7, 2022

Mandiant

Written by: Kyle Chrzanowski, Roshini Jagadam



Time is an extremely persistent threat actor observed across all industries. The group has conducted the longest running and highest volume campaigns observed among any group to date. Time appears to have formidable and global capabilities and often has secondary impacts that lead to other successful threat actor campaigns. Time has not been observed asking for payment and motivations are yet unknown.

Threat actors are increasing in number and sophistication. They can innovate and launch attacks without the need to submit 3-year

downtime windows, or go through lengthy procurement processes. Defenders are intent on reducing the risk and impact of a successful attack and are increasingly focused on improving their security posture; however, they are failing to improve the speed at which they can defend against threat actors. As seen in Figure 1, an organization losing the battle to the Nameless APT will be slower to respond and manage risk. Thus, the average risk over time will be higher, the maximum risk will be higher, and the risk will be fully remediated more slowly.

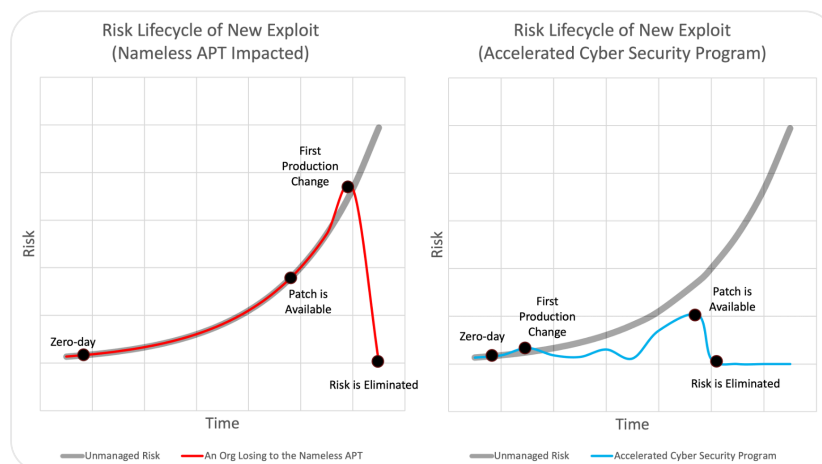


Figure 1: Risk of a sample organization that is slow to respond to a newly identified risk (left), versus an organization that can respond quickly (right)

Security teams are expected to quickly implement detections/preventions for new and novel attacks while already buried in technical debt fighting the degradation of existing security controls, all while being available to drop everything as soon as there is a security incident. Even with clear and concise objectives, many organizations are not able to complete this work fast enough to defend against the modern and high-speed attack

enough include.

- There's not enough headcount
- There's not enough budget
- There's not the right toolset
- There are not enough hours in the day
- There are constant interruptions

While these common causes are valid, the reasons organizations struggle to keep up with the security landscape often stem from a root issue:

“The way organizations work today doesn't allow them to get work done fast enough.”

Understanding Slow Work

To defend against Time and fix the core issue, we first need to understand what causes slow work and define a few key terms that help describe it.

- Queue Time (Q/T): The time something waits to be worked on (e.g., an access request waiting to be approved, a SIEM alert that hasn't been responded to, an email waiting in queue).

into an output (e.g., think about and create a SIEM rule, patch a server, conduct an access review).

- **Lead Time (LT):** The time from the moment work is ready to be worked on by an individual, team, or department until it has been completed and made available to the next person or team in the value stream (i.e., queue time plus processing time) .
- **Process Over Activity (POA):** The measure of flow within a system, expressed as a percentage. It is calculated by dividing total processing time (P/T) over total lead time (LT) (e.g., a request with LT of 5 days and a P/T of 1 day has a POA of $1/5 = 20\%$).

Percent Complete & Accurate (%C/A): A measure of the amount of waste and/or re-work within a process obtained by asking downstream customers what percentage of the time they receive work that's "usable as is" without having to correct the information, add missing information, or clarify information.

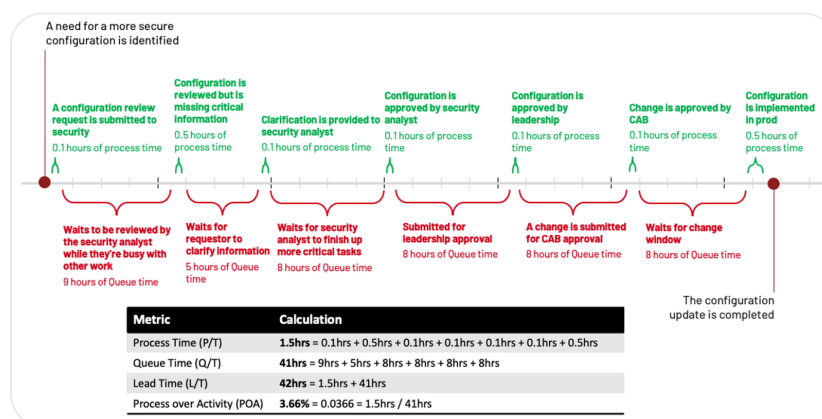


Figure 2: A sample security configuration review and update process with examples of Process Time (P/T),

Queue Time (Q/T) typically takes up the highest percentage of the total time necessary to complete work and deliver value. In the example in Figure 2, it takes over 5 full business days to implement a configuration into production even though the Process Time (P/T) is only 1.5 hours.

Organizations new to implementing an accelerated cyber program may be trying to measure and improve total work throughput without considering the aforementioned flow metrics. This is a mistake. In order to defend against Time and respond to modern threats, it is crucial to focus on increasing flow through optimization of the metrics. As these metrics are improved, the speed at which an organization can respond to threat actors is increased, efficiency increases, and total work throughput is increased.

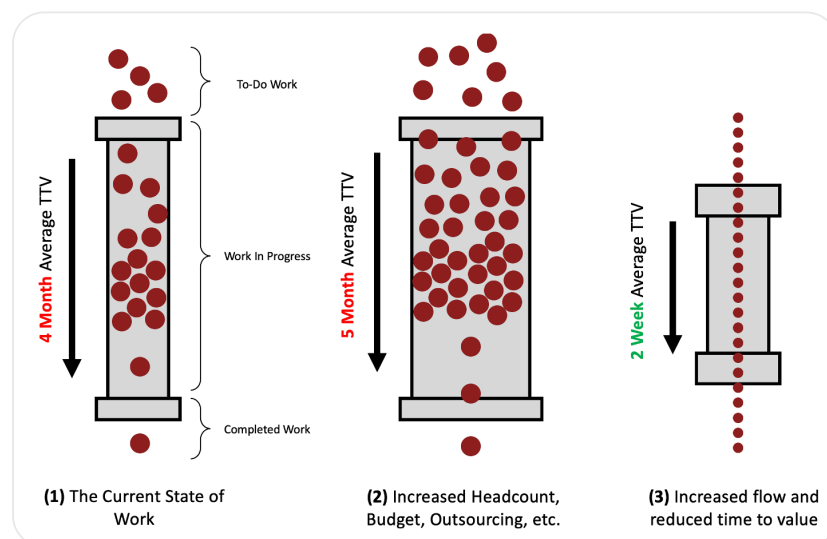


Figure 3: Security work flowing through a system where the circles represent individual work items and tasks, the length of the pipe represents the total time it takes to complete work, and the width of the pipe

As demonstrated in Figure 3, looking solely at throughput restricts your view to only what is coming out of the pipe and not the blockages or work slowdowns within security from start to finish. The focus for organizations responding to the Nameless APT should not be to create a wider pipe where larger traffic jams can happen—it should be to first decrease the length of the pipe and reduce the traffic jams within the pipe. Using the metrics in Figure 2 can help with this. As the total Lead Time (LT) decreases, the time it takes to respond to a threat actor (total length of the pipe) gets shorter. As Process over Activity (POA) increases, the gaps and spaces between work items is reduced. As Queue Time (Q/T) is reduced, the total Work In Progress (WIP) is reduced and the traffic jam in the middle of the pipe begins to clear up. As Percent Complete and Accurate (%C/A) is increased, the work stuck to the side of the pipe is reduced and the traffic jam further decreases in size or is removed entirely.

What Does an Accelerated Cyber Security Transformation Look Like?

continuing traditional ways of working.

Organizations that adopt an Accelerated Cyber Security Program defend against the Nameless APT by changing their mindset: the way they even think about “Work”. These organizations understand that no value has been provided until work is in production and that continuously improving the speed at which they’re able to identify, prioritize and add value is equally or more important than the work itself.

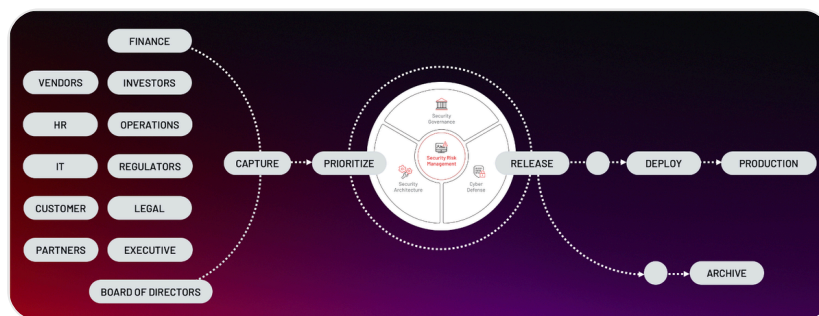


Figure 4: An example workflow of value in an organization from requirements capture to production

As illustrated in Figure 4, organizations with an Accelerated Cyber Security Program manage, plan and control work through several stages and aim to continuously improve the speed at which they are able to select and complete work. With this perspective and approach, organizations can improve the quality, speed and efficiency of their planned work in order to continuously keep up with the security landscape.

So, instead of focusing solely on attempting to increase the amount of work that is completed, they improve the speed at which they deliver value and manage risk. They do this by:

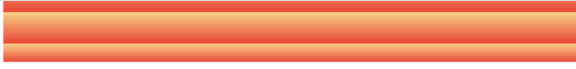
constrained resources

- Managing Work in Progress (WIP) to match labor capacity
- Reducing batch sizes and implementing feedback loops
- Operationalizing cross-functional collaboration before, during and after work is completed
- Mapping and optimizing security value streams
- Preventing local optimizations through incentives
- Fostering a culture of continuous improvement, psychological safety and smart risk taking

Each of these listed items are initiatives that should be taken when undergoing an Accelerated Cyber Security Transformation. Each additional step increases the maturity of an Accelerated Cyber Security Program and though it requires significant investment and planning to execute, it enables and increases the effectiveness of nearly every aspect of an organization's overall Cyber Security Program. Stay tuned for future blog posts digging in on each of these topics in further detail.

Posted in [Threat Intelligence](#)—[Security & Identity](#)

Related articles

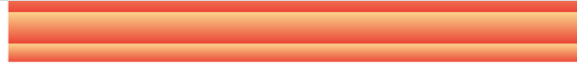


Threat Intelligence

[Threat Intelligence](#)

Vulnerability Discovery and Exploitation Trends in the AI Era

By Google Threat Intelligence Group • 17-minute read



Threat Intelligence

[Threat Intelligence](#)

Defending Against Active Exploitation of Citrix NetScaler ADC and Gateway Appliances

By Mandiant • 29-minute read



Threat Intelligence

[Threat Intelligence](#)

ShinyHunters Renewed Mass Exploitation Campaign Targeting Oracle PeopleSoft

By Mandiant • 18-minute read



Threat Intelligence

[Threat Intelligence](#)

Proactive Defense: Hardening Code Pipelines and CI/CD Infrastructure

By Mandiant • 15-minute read

Follow us

